



IT and Telecom Sector Frauds and Countermeasures



UNIVERSITY OF MADRAS
INSTITUTE OF DISTANCE EDUCATION

சென்னைப் பல்கலைக்கழகம்
தொலைதூரக் கல்வி நிறுவனம்

E.R. Ramesh, M.C.A., M.Sc., M.B.A.,

Day - 3



Roaming Fraud

- In the case of **Roaming fraud**, the billing procedure may mean that the **Subscriber is billed a long time after the calls were made**, in which case the **subscriber may no longer be billable**.
- Another aspect of this may be that the **subscriber has been identified as a fraudulent roamer**, but an **error in the procedure of terminating his subscription** means that **he is able to continue making calls whilst roaming**.

Voucher Fraud

- In the case of **Voucher fraud**, there may be **problems associated with the procedures used to produce, distribute, activate and de-activate the PAYT vouchers.**
- If the voucher information **can be distributed to a number of people who attempt to activate the voucher at the same time**, then if the **procedure provides a time window between the phone account being credited and the voucher being de-activated**, this may allow a number of people to use the same voucher.

Voucher Fraud

- Such frauds usually display normal behaviour, and can only be countered by **tightening up the procedures involved.**

PBX

- PBX (**Private Branch Exchange**) systems started out as an **internal company switchboards** where **operators manually directed calls from one person to the next.**
- **By the time the 80's rolled around,** manual switchboards had been thrown aside, replaced with **automatic switchboards** that could **route the call by itself.**

PBX

- **Fast forward to today**, where PBX technology is taking on a whole new realm, **the Internet world**.
- **Instead of routing calls through old switchboards and circuits**, today's solutions use **Internet protocol to exchange information**.

PBX Hacking

- **PBX hacking – the act of breaking into and accessing a company's PBX system and selling long distance/international telephone time to third parties – remains one of the leading types of fraud around the world.**
- It's also nothing new, having first been reported in 2005.

PBX Hacking

- Since then, it has consistently been one of the main **computer crimes reported to Fraud investigators** all over the world.
- **Telephone hackers can take over insecure PBX systems to make international and long distance calls, listen to voice mail or monitor conversations.**

PBX Hacking

- The main economic reason fraudsters hack PBX systems is to gain access to the trunk lines after which **they begin generating as many calls as possible to international premium rate numbers** that they own off which the criminal collects 90% revenue.
- Many businesses are **unaware** that they are **responsible for all calls made** from their phone system, including any **fraudulent calls**.

PBX Hacking

- More so, **victims** of hacked PBX systems are **typically unaware of any unauthorized use** and unwittingly allow the hackers to “**sell**” the use of their telephone system to others or, **far worse give the hackers the opportunity to maliciously reprogram the system.**

Fixed Network Fraud

- Network operators around the world use a myriad of **different network configurations to deliver broadband data connectivity** (Table 1).
- However, there are in essence only two substances used for transport in fixed communications networks:
 - ✓ **copper** and **fibre-optic glass**.

Fixed Network Fraud

- Copper carrier systems are further subdivided into thin “**twisted pair**” cables originally designed for voice telephony and thick “**coaxial**” cables with greater capacity, primarily installed for cable television.

Fixed Network Fraud

- There are essentially five possible types based on the distribution of these three carriers in the distribution and “**last-mile**” segments of the network.
- The divisions are not exact, as many of them **depend on how far out to the customer premises the network operator deploys fibre.**

Categories of Fixed Networks

Table 1: Categories of fixed networks

	Core	Distribution	Last Mile³
PSTN	Fibre	Twisted pair	Twisted pair
Cable TV	Fibre	Coax	Coax
Hybrid fibre coax	Fibre	Fibre	Coax
Fibre to the node ⁴	Fibre	Fibre	Twisted pair
Fibre to the home ⁵	Fibre	Fibre	Fibre

Introduction to SS7 and Security

Absence of security in SS7 is identified as a weakness, but not seen as a problem due to the following:

- ✓ Existing trust relationships amongst Telcos
- ✓ Closed networks
- ✓ Only experts are working and monitoring networks

Introduction to SS7 and Security

- Today networks are changing and protection for SS7 is becoming a necessity due to:
 - The opening of the network for various (smaller) interconnect parties and service providers
 - IP access to SS7 networks
 - Less experts available to monitor networks
 - More SMS service providers connecting to network, increasing the possibility of sending wrong messages without any purpose or trying to abuse the network.

Introduction to SS7 and Security

- Today networks are changing and protection for SS7 is becoming a necessity due to:
 - TCAP and protocols based on TCAP are more vulnerable to fraud.
 - Don't need end to end physical connections
 - Used in inter-PLMN communications Preventing SS7-Based Attacks using TCAP Security

SS7 based security threats

Spoofting - Definition:

- ✓ Illegal use of HPLMN SMSC by a 3rd party.
- ✓ An MO SMS with a manipulated A-MSISDN (real or wrong) is coming into the HPLMN network from a foreign VLR (real or wrong SCCP Address).
- ✓ If the billing is made from the SMS-C data, the real subscriber will be invoiced.

SS7 based security threats

Spoofing - Precaution:

- HPLMN can check the originator MSISDN (to verify if it's a real or not).
- HPLMN can check if the VLR location stored in the HLR is in the same range with the requesting SCCP address.

SS7 based security threats

Faking (MT Spoofing) - Definition:

- A fake SMS is originated from the international SS7 network.
- SCCP/MAP addresses are manipulated.
- SCCP/MAP addresses are wrong or copied from a real existing SMSC.
- SMS can be sent to a real subscriber (recovering IMSI) or to a wrong IMSI (only to generate traffic).

SS7 based security threats

Faking (MT Spoofing)

Precaution:

- Controlling access to the SS7 network
- Supervision of foreign SMSC traffic

SS7 based security threats

Spamming - Definition:

- Subscriber receives unwanted SMS.
- Sender can be valid.
- SMS can be billed correctly.
- SMS is submitted by a mobile phone or by a third party connected to the SMSC.
- Only real detection method is customer complaints.

SS7 based security threats

Spamming

Precaution:

- Repetitive content check
- SMS Firewall / SMS Router

SS7 based security threats

Flooding

Definition:

- Massive load of messages to one or more destinations.
- The only parameter is the number of messages sent.
- May cause denial of service

Precaution:

- Supervision of traffic

SS7 based security threats

Mobile Viruses

Definition:

- Unwanted signaling
- Stolen private information

Example:

- Hatihati

Precaution:

- SMS Defence

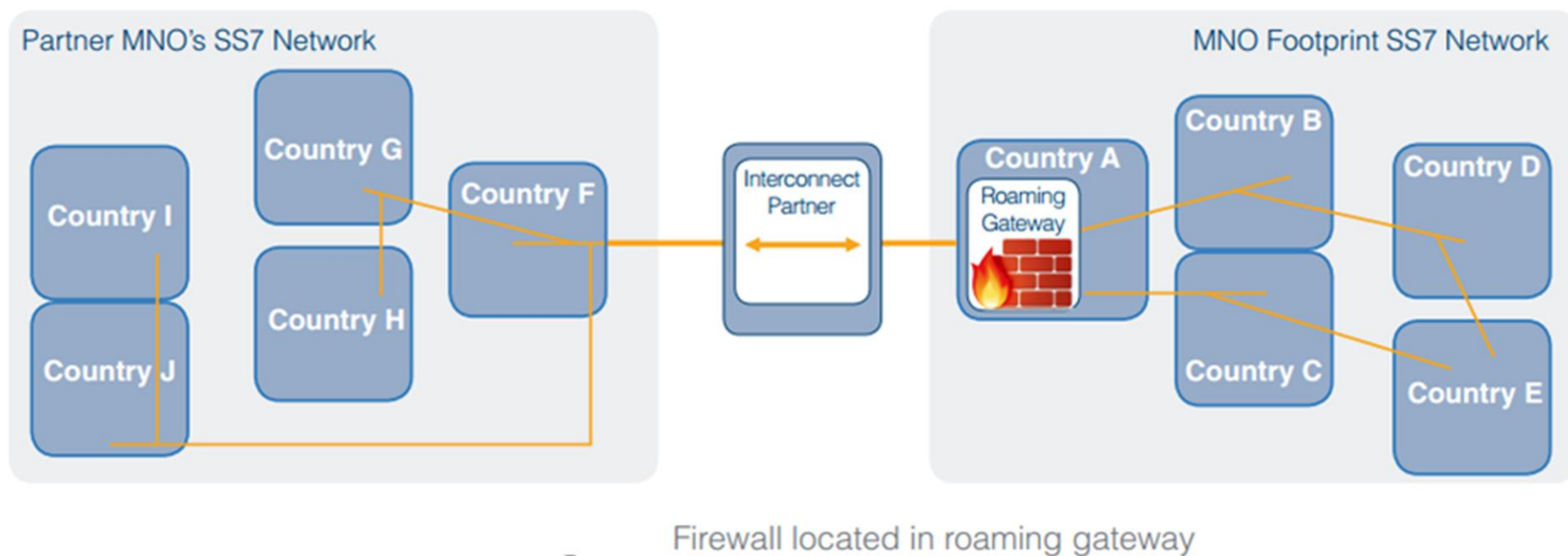
Countering the attack

- There is **no way to stop unauthorised SS7 Message Signal Units (MSU)** from being injected into networks and so a solution must work by recognising and dealing with them before they can reach their intended destination.
- One way this could be done is by **placing a firewall at a network interconnect**, for example a Signalling Transfer Point (STP) or International Gateway Exchange, and auditing MSUs as they pass through.

Countering the attack

- Packets flowing through the firewall **would be decoded and inspected** where **configured rules** would be applied and **traffic flow filtered accordingly**.

Countering the attack



Countering the attack

- Filtering rules could be applied at multiple levels of the SS7 stack to include the following parameters:
 - ✓ Application Context
 - ✓ Global Title
 - ✓ PLMN ID
 - ✓ Operation Code

Countering the attack

- Rules could be applied as blacklists, for MSUs to block, whitelists, which block all MSUs of a certain type except those specified and greylists, for events to log.
- By fully decoding MSUs at multiple levels the firewall could recognise spoofed messages, for example, by comparing the calling party digits in the Signalling Connection Control Part (SCCP) layer with those in the Mobile Application Part (MAP) layer.

Countering the attack

- By blacklisting MSUs that contain mismatches between these two layers an operator could block spoofed messages on their network.

Countering the attack

- Returning to the example of the spammer compiling a list of phone numbers, a network operator may decide to use a whitelist to block all ATI requests except those originating from a list of trusted sources.
- When the attacker's ATI requests are received by the firewall they will be rejected when the source address is not found on the list.

Countering the attack

- However, ATI requests from whitelisted sources will still be passed on.

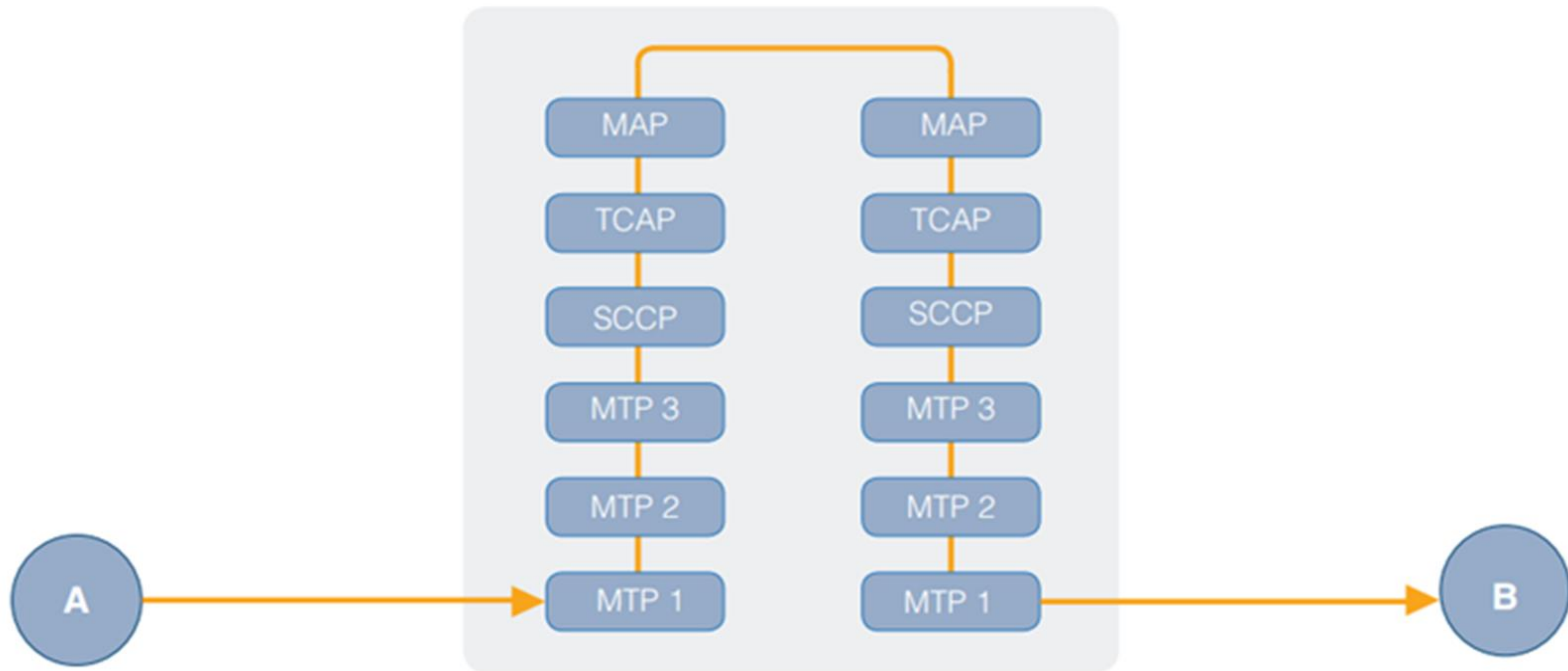
Protecting mobile networks from SS7 attacks

- Network operators' own data could also be utilised by the **firewall** to enable it to make more **sophisticated judgements** regarding MSU routing. If, for instance, the firewall had access to a subscriber's HLR '**velocity checks**' could be performed to **detect unauthorised MSUs**.
- A **location update from Australia for a subscriber who two minutes previously reported he was in France would clearly be illegitimate.**

Protecting mobile networks from SS7 attacks

- A firewall with **access to the relevant database** could be programmed to recognise this and act accordingly.

Protecting mobile networks from SS7 attacks



Full decode of MSU for multi-layer filtering

Protecting mobile networks from SS7 attacks

- To further improve the efficiency of the firewall data **could be collected in order to build a picture of statistically normal network behaviour.**
- A node that **regularly receives large numbers of update Location requests**, for example, is likely to be an HLR.

Protecting mobile networks from SS7 attacks

- If all of a sudden mt-forwardSM MSUs are detected as coming from this node it's likely they would be **unauthorised as an HLR** would not ordinarily send such a message.

Protecting mobile networks from SS7 attacks

- Building a picture of **normal network behaviour** in this way could be used to detect **International Revenue Share Fraud attacks (IRSF)**.
- IRSF attacks work by **attaining a premium rate phone number** or range of phone numbers from an **international revenue share provider**, who shares a percentage of the income generated from calls made to these numbers, and **fraudulently** initiating calls to them.

Protecting mobile networks from SS7 attacks

- Calls can be fraudulently initiated in a number of ways – **SIM theft, international call forwarding, hacking Private Branch Exchanges (PBX)** – but will often have a distinct signature when made for the purpose of **IRSF**.

Protecting mobile networks from SS7 attacks

- Known **IRSF** number ranges could be added to **black or grey lists** and **suspicious activity**, particularly **long bulk calls to a single number**, could be flagged as potentially fraudulent.
- By recognising **suspicious activity** like this as quickly as possible **the firewall would enable the network operator to take action to block the fraudulent calls**, saving money that would otherwise go to fraudsters.

Mobile Network Fraud

- Mobile security is the **protection of smartphones, tablets, laptops** and other **portable computing devices**, and the **networks** they connect to, from threats and vulnerabilities associated with wireless computing.
- Mobile security is also known as **wireless security**.

Fraud in Wireless domain

In 2012 enterprise mobile security survey polled 487 IT security professionals and IT managers. The survey found the following **top five mobile security concerns**:

- 1. **Device loss** was the **top concern**. If an employee leaves a **tablet** or **smartphone** in a taxi cab or at a restaurant, for example, **sensitive data**, such as customer information or corporate intellectual property, can be put at risk.

Fraud in Wireless domain

- According to Marcus Carey, a security researcher at Boston-based compliance auditing firm Rapid7 Inc., such incidents have been behind many **high-profile data breaches**.

Fraud in Wireless domain

2. **Application security** was the **second-ranking concern**. One problem is **mobile apps** that **request** too **many privileges**, which allows them to access various data sources on the device.

- According to Domingo Guerra, president and co-founder of San Francisco-based Appthority Inc., many mobile apps -- **especially free ones** -- are built with ties to **advertising networks**, which makes **contacts, browsing history** and **geolocation data** extremely valuable to **application developers**.

Fraud in Wireless domain

- As Guerra put it, "Developers want to monetize, **consumers want free apps** and then **ad networks will pay developers to get all of that juicy data from their users.**"
- According to survey respondents, **leaked corporate contacts, calendar items** and even the **location of certain executives** could put the company at a **competitive disadvantage.**

Fraud in Wireless domain

- Another concern is **malicious or Trojan-infected applications** that are **designed to look like they perform normally**, but **secretly upload sensitive data to a remote server**.

Fraud in Wireless domain

3. **Device data leakage** was the **third-ranking** mobile security issue. Nearly all of the chief concerns identified in the mobile security survey, from **data loss** and **theft** to **malicious applications** and **mobile malware**, are **sources of data leakage**.

- While **most corporate access privileges on mobile devices remain** limited to calendar items and email, new mobile business applications can tap into a variety of sources, if the enterprise accepts the risks, said mobile security expert Lisa Phifer.

Fraud in Wireless domain

- **Increased corporate data on devices increases the draw of cybercriminals who can target both the device and the back-end systems they tap into with mobile malware, Phifer said.**
- **"If you're going to put sensitive business applications on those devices, then you would want to start taking that threat seriously."**

Fraud in Wireless domain

4. **Malware attacks** were the **fourth-ranking** mobile security concern. A new report from Finland-based antivirus vendor F-Secure Corp. found the vast majority of mobile malware to be **SMS Trojans, designed to charge device owners premium text messages.**

- **Experts say Android devices face the biggest threat,** but other platforms can attract financially motivated cybercriminals if they adopt **Near Field Communications** and other mobile payment technologies.

Fraud in Wireless domain

- An F-Secure analysis of more than **5,000** malicious Android files found that **81%** of mobile malware can be classified as Trojans, followed by monitoring tools (**10.1%**) and malicious applications (**5.1%**).

Fraud in Wireless domain

5. Device theft was **fifth** on the list of top concerns. **Smartphone theft** is a common problem for owners of highly coveted smartphones such as the **iPhone or high-end Android devices**.

- The **danger of corporate data**, such as **account credentials** and **access to email**, falling into the hands of a tech-savvy thief, makes the issue a major threat to the IT security pros who took the survey.

Common Telecom Frauds

Clip on

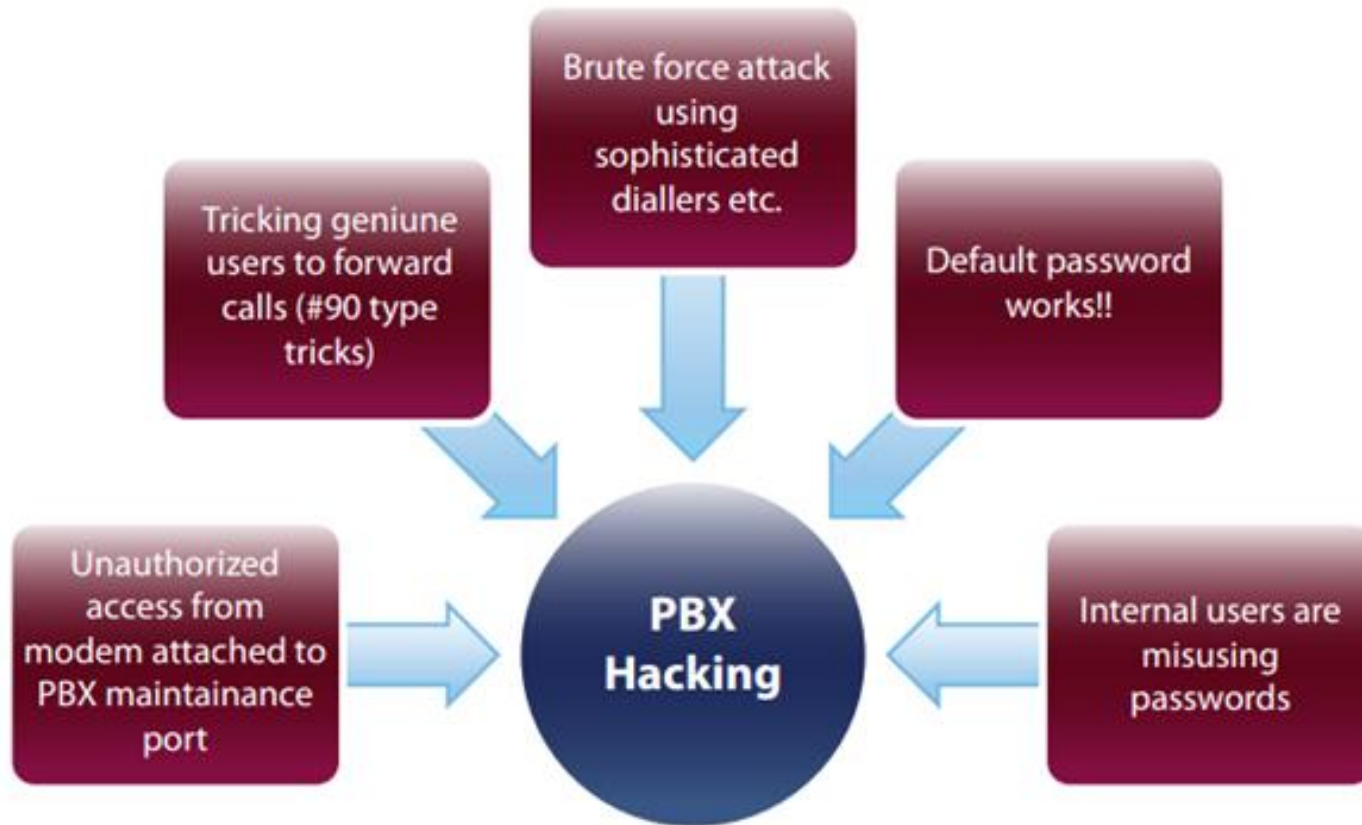
- **Illegal parallel connection on the subscriber line** and make someone else pay for the calls.

Boxing Fraud

- **Illegal stressing of national or international channel associated signalling systems.**

PBX Hacking

Popular methods of hacking PBXs are summarized in diagram below



Brute Force Attack

- Typically, the PBX security is breached via the **toll-free Direct Inward System Access (DISA) number**.
- Many PBXs **allow dial-through**, wherein a person calling into the PBX can **access an external line by using appropriate passwords and control sequences**. Large corporates use this feature extensively.

Brute Force Attack

- Fraudsters **hack into the PBX, obtain passwords** and once a password is retrieved, use the PBX to **generate outbound calls**.
- “**War dialling**” is one of the techniques used for **obtaining passwords**. It involves the fraudster trying to break PBX code using an auto dialler, which keeps on dialling same number in a sequence making an exhaustive search of passwords until it breaks through.

Default passwords

- One of the **largest contributing factors in PBX hacking and misuse is careless PBX installation and poor configuration, leaving default user and maintenance port passwords** in place (fraudsters know the default passwords for the various switch vendors).
- PBX fraud commonly occurs when the **customer fails to change the default password or do not change passwords frequently**. Default passwords can be found online in the relevant PBX user manuals etc.

Default passwords

- Telco and PBX vendors should advise corporate customers to changes all **default settings and passwords**.
- This will **prevent easy hacking opportunities for fraudsters**.

Internal Enemy

- Many cases of PBX hacking result from insiders or vendors who disclose the phone numbers, IDs and passwords necessary for breaching PBX security.
- Sometimes the users may get hold of passwords by unauthorised means and use the corporate lines for making personal calls or colluding with external fraudsters to help in PBX hacking.

Internal Enemy

- **Strict security Policies** should be in force for PBX password control.
- The **physical security of PBXs and phone extensions** is also an important factor to consider in **avoiding misuse of PBXs**.

Social Engineering

- **The old traditional (wired) phone scam involving the 90# buttons on corporate telephone lines is still around.**
- **Employees of a corporation using a PBX line from their desk, receives a call from someone claiming to be a telephone company employee **investigating technical problems with line, or checking up on calls supposedly placed to premium rate services or other countries from your line.****

Social Engineering

- The caller asks the employee to aid the investigation by **either dialling 90#** (or similar combination) or **transferring him/her to an outside line before then hanging up the telephone receiver.**

Social Engineering

- By doing this the **employee will be enabling the caller to place calls that are billed to the corporate telephone account.**
- This attack **only works on few PBXs today.**
- **Social engineering** is another common technique used for **obtaining passwords.**

Discuss – Attack vectors for Social Engineering

Service Port

- PBX hackers may also **target modems** attached to the **service PORT of a PBX**. The facility is provided by PBX manufacturers to allow remote support of the PBX.
- Typically, the **connection should be opened only when an authorized request goes from the PBX customer to the PBX vendor**, but many PBX customers **keep the connection always open and therefore prone to attack**.

Unauthorized disclosure of information

- **Loss, misuse, modification, or unauthorized access to sensitive information can adversely affect the privacy or welfare of an individual, trade secrets of a business or even the security and international relations of a nation depending on the level of sensitivity and nature of the information.**

Unauthorized amendment of data

- The **unauthorized changing of data before or during their input to a computer system.**
- Examples are **forging or counterfeiting documents** and **ex- changing valid computer tapes or cards with prepared replacements.**

Denial of Service (DoS) attack

- In computing, a **denial-of-service** (DoS) attack is an attempt to make a machine or network **resource unavailable to its intended users**, such as to **temporarily or indefinitely interrupt or suspend services** of a host connected to the Internet.

Cloning

- **Cloning** is the best-known type of **telephone fraud**, afflicting analogue networks in particular. Cloning is the practice of **programming the identity of a legitimate phone into another phone**.
- The details of its identity are usually obtained either by eavesdropping on its interaction with the **base station** or by stealing it.

Cloning

- **Calls are then billed to the owner of the legitimate phone.** Cases of multiple clones of the legitimate phone have been reported. This clearly multiplies the resultant financial exposure.
- At some point, the **legitimate owner protests and is issued with a new identity**, with the previous one being barred.

Cloning

- To counter this, criminals have a variant on cloning called “**tumbling**”, whereby a phone is programmed with the identities of many other phones (99 in one case).
- Each time a call is made, the **phone rotates between its identities**, lessening the chance of detection and ensuring that the phone will work until all the accounts are barred.

Cloning

- **Cloned phones are often sold with a guarantee that they will work for a given number of months - if the clone is detected and the account is barred the supplier will replace it free of charge in the guarantee period.**

Cloning in GSM Networks

- **Phone's authentication parameters are copied into other handsets**, so that the network believes that it is the original handset that is being authenticated.
- The telecom **company charges the calls to original customer** who will obviously deny having made such calls and consequently the telecom company will lose its revenue.

Cloning in GSM Networks

- It allows fraudsters to make high value calls for which the telecom company cannot collect any revenue.
- In addition, in most cases of cloning, the operator will have to make substantial payments to other telecom companies.

Tumbling or Magic Phone

- **Tumbling phones** automatically seek an identity from a **pre-programmed** list, and **Magic phones** act as their **own scanners copying identities from nearby phones in use**.

Dealer or Reseller Fraud

- **Dealer fraud** happens when a dealer / partner / third party supplies equipment or services with the intention of **depriving the operator of revenue and increasing their own commission.**
- This often includes **false activation of accounts** and the **resale of devices, equipment or services outside the terms and conditions** of the contract.

Theft

- Despite an **often-subsidised selling price**, the handsets are valuable in themselves as well as in the network access, which they provide.
- They are thus an **attractive target** for theft. In the **window of time before the theft is reported** and the **account barred**, many **high value calls** can be placed, particularly using **call-forwarding features** to stack up multiple simultaneous calls. Alternatively, the **phone may be cloned**.

Pre-paid Cards

- Pre-paid **subscription cards** have been designed to allow a subscriber to pay for a certain value of calls in advance.
- This is an **attractive proposition** in that the **subscriber has little opportunity**.

Social Engineering and Friendly Frauds

- Social engineering, in the context of information security, refers to psychological manipulation of people into performing actions or divulging confidential information.
- A type of confidence trick for the purpose of information gathering, fraud, or system access, it differs from a traditional "con" in that it is often one of many steps in a more complex fraud scheme.

Social Engineering and Friendly Frauds

- The term "social engineering" as an act of psychological manipulation is also associated with the social sciences, but its usage has caught on among computer and information security professionals.
- Some of the techniques are Pretexting, Diversion theft, Phishing, phone phishing, Tailgating.

Insider Fraud

- Insider fraud is perpetrated by a malicious insider, which is a current or former employee, contractor, or other business partner who has or had authorized access to an organization's network, system, or data and intentionally exceeded or misused that access in a manner that negatively affected the confidentiality, integrity, or availability of the organization's information or information systems.

Identity Theft

- Identity theft is a form of stealing someone's identity in which someone pretends to be someone else by assuming that person's identity, usually as a method to gain access to resources or obtain credit and other benefits in that person's name.

Local Subscription Fraud

- Subscription fraud, which is defined as the use of telephone services with no intention of paying, is probably the most significant and prevalent worldwide telecom fraud. Subscription fraud can be subdivided into two categories:
 - a) for profit, i.e. mainly for selling long distance calls and
 - b) for personal usage. Subscription fraud can be committed upon fixed and mobile telephones, and it is usually difficult to distinguish from bad debt, particularly if the fraud is for personal usage.

Roaming Subscription Fraud

- To be truly useful, mobile phones should allow roaming between networks and across countries.
- However, fraudsters can exploit the time lag in sharing account activation and billing data between these operators.

Roaming Subscription Fraud

- For example, a user can evade billing limits set by his home network by making high value calls whilst roaming across other networks.
- It is even possible to close the account in the home country, but still use the phone abroad for a certain period.
- Faster data transfer between operators - preferably by EDI - is the most effective solution to this problem.

Content and Value Added Frauds

- Telecom Companies are providing Premium Rate Numbers (i.e. 52222, 59999, 57777 etc.) to their customers for value added services, wherein, all calls are charged at a very high rate.
- Content provider for Premium Number Service is entitled for revenue share on the basis of the number of incoming calls.

Content and Value Added Frauds

- In such a scenario, a content provider may try to get the maximum number of calls using all tactics e.g. content provider may obtain another number with fraudulent documents / information with no intention to pay the bill and will make calls to Premium Rate Number for getting higher revenue.

Content Sell Fraud

- The fraudster replicates and re-sells premium content, such as video or music less, at a fraction of the normal rate.
- This includes content resale (pirating) and IP infringement.

Content Artificial Inflation Fraud

- *This* is similar to traditional premium rate service (PRS) attack, but is increasingly associated with content downloads.
- It leaves the operator unable to collect fees from the fraudulent service use, but would be obliged to pay the content provider.

Click Fraud

- In addition to content ALT, a specific type of internet-based fraud-commonly known as 'click fraud'. The fraudulent PRS content provider drives traffics to a paid content Website.
- This may be done manually, or by injecting phishing, malware to automatically use the service or hacking an operator's network to divert track to a content service, similar in nature to older auto-dialer attacks.

Crossover Fraud

- Fraudster sends a “Trojan” to legitimate 3G subscribers. The Trojan causes the mobile devices of subscribers to automatically use service without the subscriber’s authority or knowledge.
- This is commonly used to make premium rate calls that inflate revenues to the fraudster’s own service.

IP Frauds

- Networks adopting VoIP entice Hackers and criminals to capitalize on any weaknesses in the technology.
- VoIP is merely a transport protocol running on a data network which from a security viewpoint, is susceptible to all the attacks commonly targeted against data networks, even if they are not explicitly targeting voice over IP.

Malware

- This general term applies to software that secretly installs viruses, key-loggers, etc - or malicious code executed on a computing device.
- It is another emerging fraud category that involves infecting devices with viruses and Trojans resulting in unauthorized actions. This might include making calls, deleting or stealing data.

Malware

- Once installed, unknown to the subscriber, a number of activities can take place, such as connections to PRS numbers, blocking calls, sending bulk SMS, or forcing legitimate services to fail.

VoIP Bypass and IP Spoofing

VoIP Bypass

- This fraud involves diverting legitimate fixed-line or mobile originating voice traffic into VoIP sessions.
- This results in a loss of revenue for the terminating operator.

VoIP Bypass and IP Spoofing

IP Spoofing

- Use of IP spoofing (substitution of identity information) is the most common method, often to aid other frauds by offering anonymity to the fraudster.

Spamming / Phishing

- Spamming and phishing refer to messages (usually randomly) sent out, typically to trick customers into disclosing credit card numbers, account passwords or banking information, or to prompt them to call a PRS service.
- Such email / SMS/MMS messages often purport from spoofed mail address.

Spamming / Phishing

- Spam over Internet Telephony (SPIT) consists of unsolicited bulk messages that are broadcast to phones connected to the VoIP WLAN network.
- Fraudsters send voice messages (such as PRS call-back or marketing spam) in bulk. Methods include hacking into a computer used to route VoIP calls to target a large number of subscribers.

Spamming / Phishing

- ***Selective Phishing*** – aimed at a specific group of individuals such as key workers within a company who may be dealing with customer details or financial data.
- ***Broadcast Attack*** – aimed at anyone randomly selected from a large group of individuals.

Money Laundering

- With the increase in m-commerce applications, micro-payments, and e-wallet/purse implementations, many new opportunities are opening up for money laundering.
- For example, use of phishing type emails to recruit persons to help with money transfers i.e. messages to recruit financial couriers in order to transfer their funds from one world location to another.

Money Laundering

- Money laundering may also be conducted in a virtual IP environment, although recent controls are making this much more difficult e.g. “Second Life” where Linden Dollars could be exchanged for actual currency allowing movement money.

Frauds in 3G Networks

3G Technology Features, Advantages and Drawbacks

- Third-generation wireless technology is the advanced wireless technology. This technology enhances the features that were available in second generation and adds further advanced features.
- This technology is widely used in mobile phones and data cards.

Features of 3G

- The ITU (International Telecommunication Union) has proposed 3G telecommunications standards to provide cost efficient high quality, wireless multimedia applications and enhanced wireless communications.
- The features of 3G can be divided into two categories. One is data rates and the other is security.

Features of 3G

- The main feature of 3G technology is that it supports greater voice and data capacity and high data transmission at low-cost. 3G mobiles can operate on 2G and 3G technologies.
- The second major feature is the security: 3G offers greater security features than 2G like Network Access Security, Network Domain Security, User Domain Security, Application Security.

Features of 3G

- This technology provides localized services for accessing traffic and weather updates. Video calls and video conference is another major feature in 3G mobile technology.
- These features reduces the communication barriers between people, that were not sacked even with mobile phones.

Features of 3G

- Data transfer rates are high and can support even live TV channels over phone. Online media is another exciting feature in 3G mobiles.
- 3G mobiles highly attract the music lovers as they can listen to music and watch videos online and can download huge files with in less time.

Features of 3G

- New 3rd Generation (3G) services “have been built to create a strong attraction, almost addictive or viral in nature”.
- 3G is a short term for third-generation wireless, and refers to near-future developments in personal and business wireless technology, especially mobile communications.
- This phase is expected to reach maturity between the years 2003 and 2005.

Features of 3G

- The third generation, as its name suggests, follows the first generation (1G) and second generation (2G) in wireless communications.
- The 1G period which began in the late 1970s, featured the first true mobile phone systems, known at first as "cellular mobile radio telephone."

Features of 3G

- The 2G phase began in the 1990s, and much of this technology is still in use.
- The 2G phone features digital voice encoding, and examples include Code Division Multiple Access (CDMA), Time Division Multiple Access (TDMA), and Global Standard for Mobile (GSM) Communications.

Features of 3G

- Since its inception, 2G technologies have steadily improved, with increased bandwidth, packet routing, and the introduction of multimedia.
- The present state of mobile wireless communications is often called 2.5G, the best example being the Global Packet Radio System (GPRS).

Features of 3G

- Ultimately, 3G, which is being delivered primarily on the Universal Mobile Telecommunications System (UMTS) platform, is expected to include capabilities and features such as:
 - Enhanced multimedia (voice, data, video, and remote control)
 - Usability on all popular modes (cellular telephone, e-mail, paging, fax, videoconferencing, and Web browsing)
 - Broad bandwidth and high speed (upwards of 2 Mbps)

Features of 3G

- Routing flexibility (repeater, satellite, LAN)
- Operation at approximately 2 GHz transmit and receive frequencies
- Roaming capability throughout Europe, Japan, and North America

Features of 3G

- The ultimate 3G system will be operational from any location on, or over, the earth's surface, including use in homes, businesses, government offices, medical establishments, the military, personal and commercial land vehicles, private and commercial watercraft and marine craft, private and commercial aircraft (except where passenger use restrictions apply), portable (pedestrians, hikers, cyclists, campers), and space stations and spacecraft.



Hypermarket of 3G Services as defined by Nokia.
Source: Nokia, Make Money with 3G Services White Paper.

Hypermarket of 3G Services

Fraud issues in 3G

- Fraud can also be expected to evolve in 3G. Today, the motive of the typical fraudster is to generate traffic to expensive destinations, such as international numbers or premium rate service lines.
- Calls may be of long duration or high volume, but the value of the fraud is a direct function of the volume of traffic.

Fraud issues in 3G

- Under 3G, this will change. In the context of broadband services, billing will be based on a combination of data volume and quality of service (e.g. bandwidth priorities, etc.).
- Where micro payments are employed, fraud will involve many small transactions that will be very difficult to distinguish from normal purchases.

Fraud issues in 3G

- This means that much of the reasoning behind today's fraud management systems and processes will become redundant in 3G, and new thinking about solutions will be required.

Fraud issues in 3G

- Some of the typical fraud issues in the early 3G networks are expected to be:

Subscription fraud

- This involves applications for service with faked ID or stolen and other documents, to get by credit checks and allow the use of telephone services with no intention to pay the ultimate bill.

Fraud issues in 3G

Credit card fraud on M-Commerce

- Purchases of goods and services on the Internet or from sites hosted by operators themselves will continue under 3G, and the credit card will remain as one payment option.

Fraud issues in 3G

Credit card fraud on M-Commerce

- Credit card fraud (card theft, forgery and transaction repudiation fraud) is very widespread in existing services and this pattern can be expected to repeat itself in 3G services.

Fraud issues in 3G

Micro payment fraud

- Possibly using subscription fraud as the primary technique, fraudsters can be expected to purchase goods using micro-payments, charged to their 3G-phone account, and then default on payment, possibly having re-sold those goods for cash.

Fraud issues in 3G

Premium Rate Service (PRS) fraud

- This is already a problem today, with some operators of PRS lines (e.g. sex lines) organising fraudulent calls to their own numbers in order to inflate incoming traffic and up their revenues.
- Under 3G, PRS will take new forms, with streaming video and audio, as well as still images being downloaded and viewed for a fee.

Fraud issues in 3G

Premium Rate Service (PRS) fraud

- Clearly, the same type of fraud as that which occurs today will be possible on these new services.

Fraud issues in 3G

Copyright infringement and content resale frauds (‘piracy’)

- As music and video become mainstream products within the 3G portfolio, we can expect sophisticated attacks on this media designed to support illegal copying and resale, in the same fashion as VCD and DVD pirating is carried out today.
- This will be an obvious draw for organised crime.

Fraud issues in 3G

Other Security & Law Enforcement Issues in 3G

- Even at this early stage in the development of future services, it is apparent that the new capabilities that will be made available to the general public, with only minimal credit vetting and proof of identity requirements, offer significant opportunities for exploitation by the criminal element and by terrorists.

Fraud issues in 3G

- Here are a few simple examples of possible scenarios:

Multi Media Messaging & Terrorism

- A terrorist commander in a remote mountain hideaway in the Middle East requires a coordinated attack on several targets in the USA by separate operational cells.

Fraud issues in 3G

- Information gleaned during the first attack will determine the exact target for subsequent attacks, but time is the critical factor as the follow-up attacks must be conducted before homeland defence forces can execute their contingency plans.

Fraud issues in 3G

- For security reasons, communication between each cell is prohibited, and it is also suspected that e-mail and voice communication to the commander may be monitored.
- However, using 3G pre-paid mobile handsets, obtained with only minimal security checks (easily bypassed) and the multi-media messaging service, operatives can photograph their targets and mission results, add text and audio, and transmit the results to any compatible handset in the world in a few seconds.

Fraud issues in 3G

- Under 3G, secure, encrypted, high speed data communications will have been placed in the hands of every terrorist, current or potential, in the world.

3G Pre-paid Services and Money Laundering

- A drug dealer has collected substantial sums of cash from his dealings and wishes to lodge this in various onshore bank accounts without raising suspicion.
- He uses his team to take out a number of pre-paid subscriptions, using faked identities. He then has his team members buy large denomination pre-paid top-ups in large volume, and he credits each account with several thousand dollars.

3G Pre-paid Services and Money Laundering

- Using these heavily topped-up handsets, the dealer now purchases large quantities of merchandise in this simplified scenario.
- He then retails this merchandise from local stores, which he has rented or purchased, and lodges the proceeds in the bank, as legitimate takings from commerce.

3G Pre-paid Services and Money Laundering

- 3G in conjunction with the pre-paid service concept and loopholes in subscriber vetting and identification, places a sophisticated financial device capable of extensive cross-border utilisation in the hands of anonymous organised criminals, again on a global basis.

Fraud Management System

- With the rapid development of telecom industry and enlarged user groups, various types of fraud have continuously emerged and caused great losses to telecom operators' revenues.
- By employing the data mining technology, FMS (Fraud Management System) analyzes existing frauds and obtains their features.

Fraud Management System

- By monitoring customers' consumption behavior, it promptly discovers and prevents any fraud happening again.
- By studying the existing consumption behavior of each customer, the FMS establishes a "fingerprint base" for everyone and monitors his consumption behavior.

Fraud Management System

- This aims to find each customer's abnormal consumption behavior and prevents any new fraud happening.

Fraud Management System

Fraud Management System - Benefits

Flexible Double-layer Architecture

- The FMS employs double-layer architecture which enables fraud detection to separate from fraud rule base. It can promptly update the fraud rule base while monitoring operators' new products and services fast.
- This enables operators to be kept away from any loss caused by fraud while promoting customer satisfaction level.

Thorough Protection Network

- The FMS can prevent existing fraud, such as purposive default, theft of telephone calls, voucher card fraud, and distributor fraud. Meantime, it promptly finds customers' abnormal behavior and prevents new fraud happening by comparing their consumption behavior with their **'fingerprint base'**.

Fraud Management System - Benefits

Intelligent Warning

- Upon finding any doubtful fraud, the FMS will immediately generate an alarm and guide alarm personnel to process it according to existing fraud cases and operators' solutions and suggestions.
- At the same time, it can automatically process this alarm as configured.

Flexible Rule Setting

- By employing the data mining technology, the FMS can automatically generate various fraud-prevention rules.
- Besides, it provides a powerful manual setting function so that operators can integrate their own fraud-prevention experience into this system.

Fraud Management System - Benefits

Thoughtful Analysis Functions

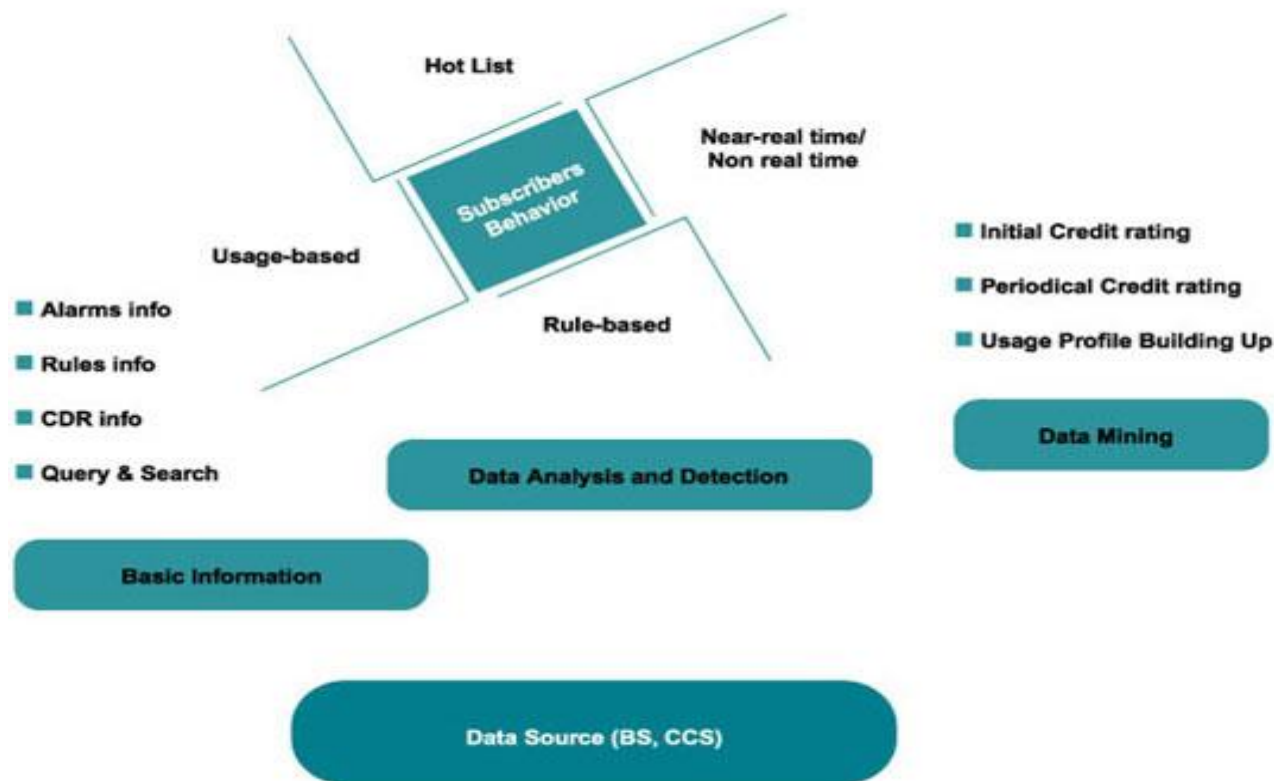
- The FMS is capable of analyzing existing fraud so that operators can promptly find their service defects and block the source of fraud.

High Security

- The FMS provides individual security management. It guarantees product security while preventing any fraud from users.

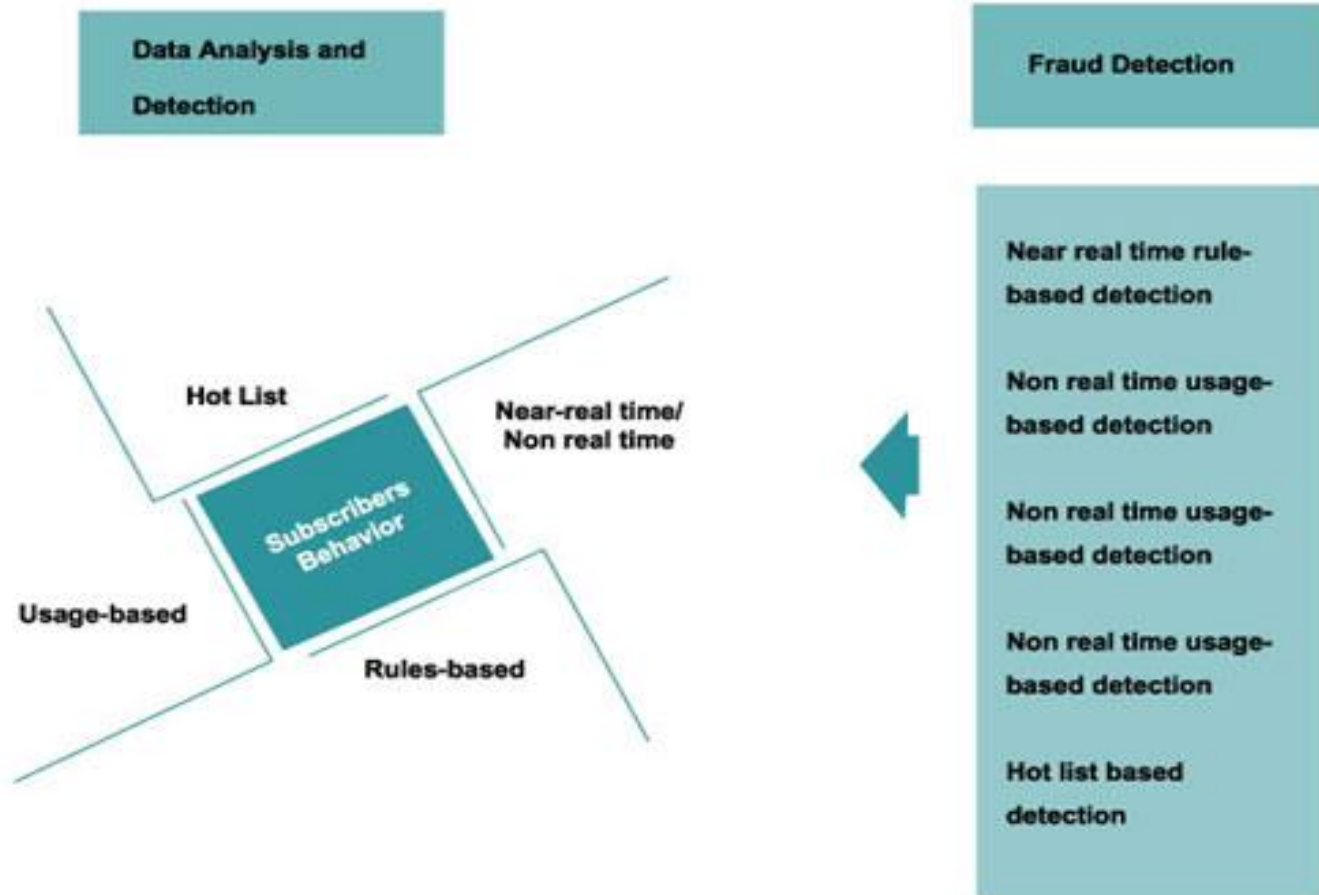
Fraud Management System - Benefits

Functionality



Functionality of Fraud Management System

Fraud Detection



Fraud Management System - Benefits

- According to the customer fingerprint base and the fraud rule base, FMS monitors telecom services in different ways: real time or non-real time, so as to find out any fraud and suspected fraud.
- When finding such cases, the system will alarm and provide corresponding handling suggestions, for operators' reference.

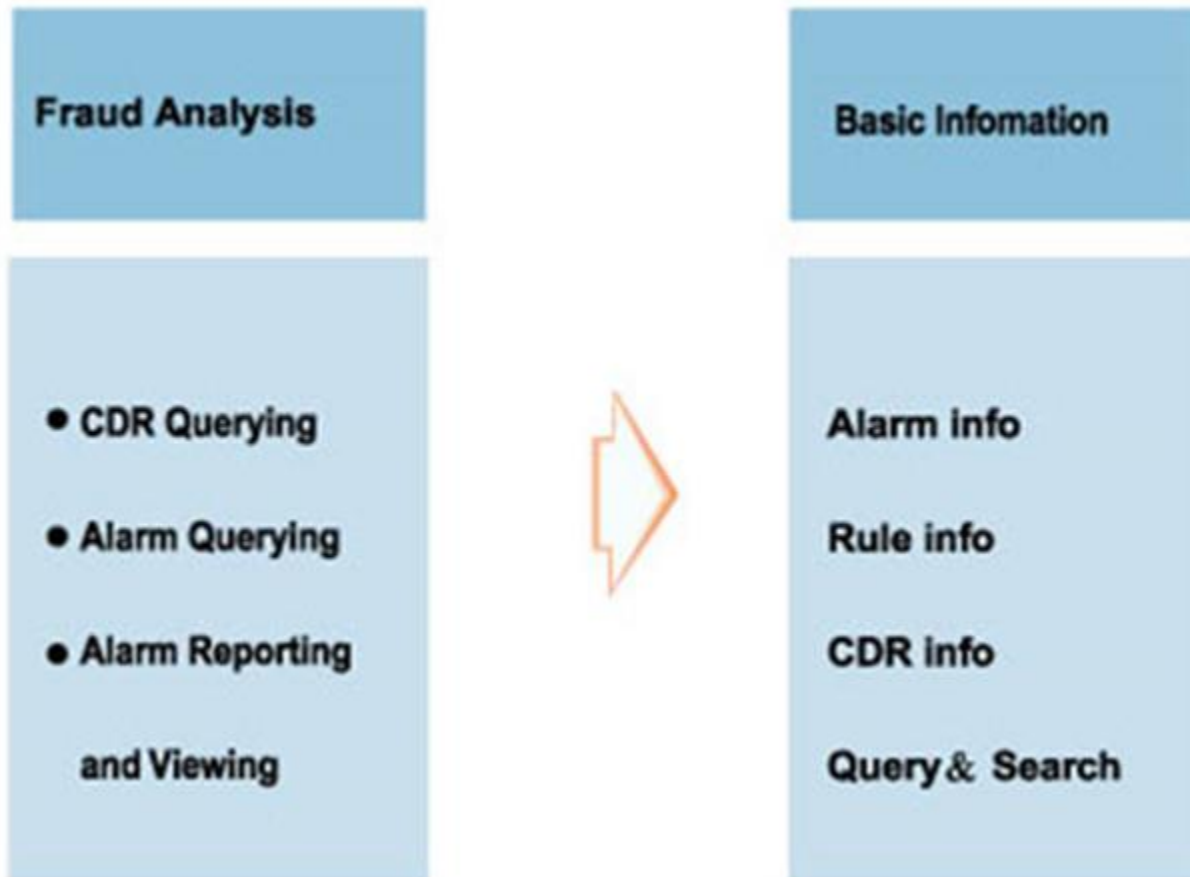
Fraud Management System

Fraud Analysis

- The FMS product helps telecom operators not only stop any fraud but prevent it happening.
- Relying on the fraud analysis of the FMS product, operators can find the cause of any fraud and perfect their operating system.

Fraud Management System

Fraud Analysis



Fraud Management System

Learnt approach

- In the learnt approach, a tool will learn what is typical behaviour, and raise an alarm on any large variations from this behaviour.
- In addition, the tool will generally evolve this typical behaviour over time as the Users behaviour changes.

Fraud Management System

Learnt approach

- The tool's ability to monitor the behaviour of the User makes it very useful for detecting frauds about which nothing is known, as in nearly all cases of hacking or contractual fraud, these will result in changes of behaviour.
- If little is known about the fraud that exists in a system, this is a good tool to begin obtaining examples of fraudulent behaviour.

Fraud Management System

Learnt approach

- However, there are a number of drawbacks with such an approach.
- It is not possible to teach such a tool what to look for, and if the evolution parameters are not set correctly, clever fraudsters will learn how to 'ramp up' usage so as not to trigger an alarm.

Fraud Management System

Learnt approach

- An example of such a tool is the Unsupervised Neural Network. Here, the inputs to the tool are measured to determine a set of parameters that describe the behaviour of the User.

Fraud Management System

Learnt approach

- The tool will typically maintain a measure of recent behaviour and longer term behaviour, and is then able to assess the current behaviour against both recent and long term behaviour profiles.

Fraud Management System

Learnt approach

- These profiles will evolve in time according to some evolution parameters that will either be dependent on time or the number of calls.

Fraud Management System

Taught approach

- In the taught approach, examples of fraud have been obtained. These are then used to 'teach' the tool what it is looking for.
- In the case of a Rule Based System, the fraud examples are analysed for their fraud signatures, and these are then translated into rules using thresholds or relative measures.

Fraud Management System

Taught approach

- In the case of a Supervised Neural Network, examples of fraud are used along with examples of non-fraudulent behaviour to teach the tool which behaviours are good and which are fraudulent.

Fraud Management System

Taught approach

- Both approaches should identify behaviours in some sense similar to the fraud examples used as fraudulent, and behaviours in some sense similar to good behaviour should be deemed non-fraudulent.

Fraud Management System

Taught approach

- There are some differences between the Rule Based and Supervised Neural Network approach that should be noted.
- In the case of the Rule Based system, work has to be done at the beginning of the fraud process to identify the signatures and thereby the rules required to detect fraud.

Fraud Management System

Taught approach

- However, having done this work, the meaning of and reason for any alarm is immediately apparent.
- For example, if calls of duration greater than 1,000 hours is a good indicator of fraud, then an alarm raised by a Rule Based system will say that this alarm was raised because the call duration was greater than 1,000 hours.

Fraud Management System

Taught approach

- In the case of the Supervised Neural Network, far less work has to be done at the beginning of the fraud process, as the tool simply needs to be taught against good and bad behaviour.

Fraud Management System

Taught approach

- However, any alarm that is raised will simply inform you that the Users behaviour is some measure of distance away from a fraudulent example.
- The analysis then has to be performed at the end of the process, by doing some further exploration of the behaviour.

Fraud Management System

Taught approach

- Although some Supervised Neural Network tools simplify this process, it is still more labour intensive than a Rule Based approach.

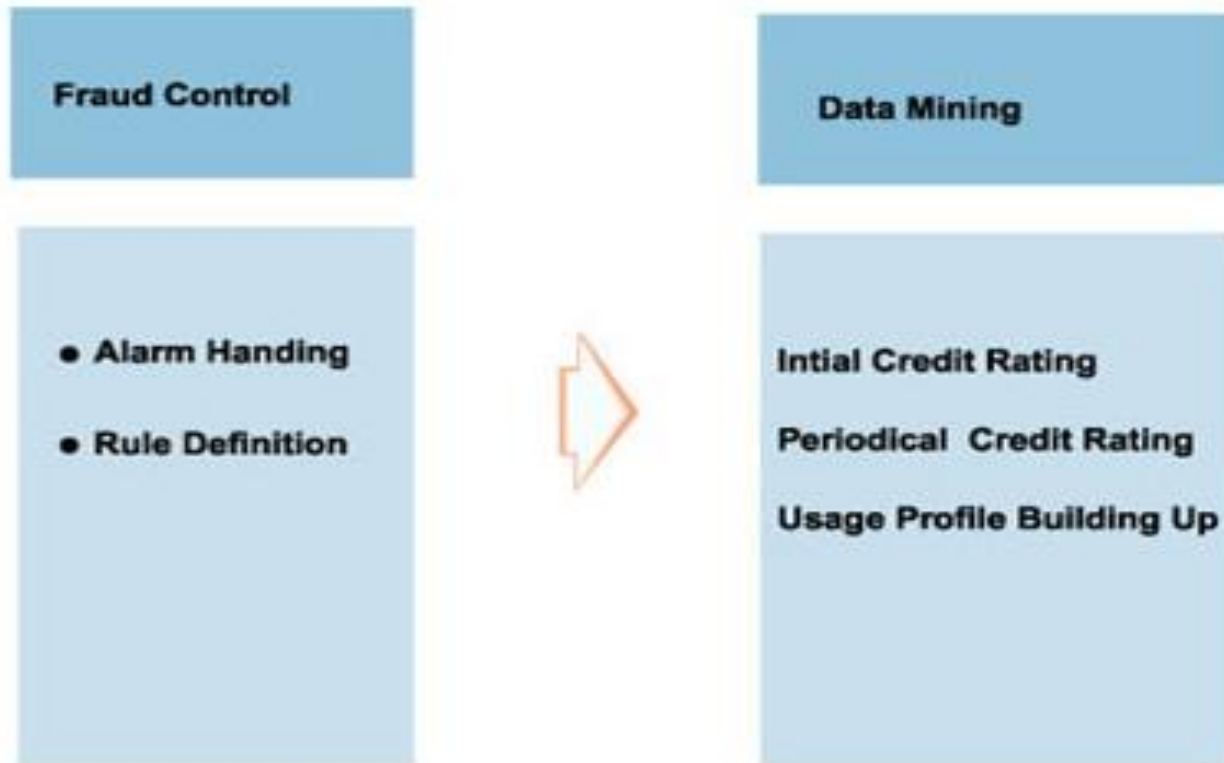
Taught approach

- However, both of these approaches have the drawback that new types of fraud are not being looked for, and may therefore remain undetected by the 'taught' tool whilst it may be detected by the 'learnt' tool.

Management of Fraud Rule Base

- Management of fraud rule base is the core of an FM product. We analyze the service use behavior of existing customers and frauds by employing data mining technology.
- Now we have obtained the following rules:
 - User fingerprint base
 - Credit rating rules
 - Fraud-prevention rules
 - Fraud alarm handling rules

Management of Fraud Rule Base



Preventive actions

Telco Customer

- Should be informed of potential security threats to the PBX;
- Should maintain and enforce good security policies for the PBX;
- Should educate employees about threats (especially social engineering related) used for PBX hacking;

Preventive actions

Telco Customer

- Should ensure physical security of the PBX, phone lines and other equipment;
- Should Monitor international calls and high value services use through the PBX.

Telco protection through the FMS

- Simply by monitoring high usage for types of calls or traffic not expected for corporate customers.
- PRS calls, content download, and international calls to high-risk countries during unusual hours (e.g. night or weekend) can be good indicators that a company's PBX has been penetrated.

Telco protection through the FMS

- Since many companies don't closely monitor their detailed phone bills on a line-by-line basis, this can otherwise go unnoticed for long periods of time.
- FMS rules should be configured for off peak monitoring with appropriate filters and thresholds, high usage monitoring for PRS, content and International services, hotlist rules for high risk country codes and equipment identifiers.

Telco protection through the FMS

- It is advised that xDRs (Usage record) processed in the FMS should have a field indicating whether a call originated or terminated at PBX.
- Once PBX hacking is detected, similar compromised lines can be identified based on behavioural profiles of blacklisted subscribers.

Telco protection through the FMS

- Authorization failures from PBX (or Voicemail) authentication can be monitored using rules on logs.
- Profiling can be used to spot sudden changes in volume and/or the nature of use of PBXs.
- Again this is a strong indicator that a PBX has been hacked.

Telco protection through the FMS

Investigative approach

- The investigative approach is, as it suggests, a matter of auditing the procedures and technology that is employed.
- This can be performed either internally or by using an external company.

Telco protection through the FMS

Investigative approach

- Such an approach is extremely useful, and will become more important as exploiting procedural and technical frauds become more attractive.

Telco protection through the FMS

Investigative approach

- One example of its usefulness is in ensuring that an employee cannot modify a database on your network so as to grant credit or free usage to certain subscribers.

Telco protection through the FMS

Investigative approach

- Another is that the machines on your network can not be accessed remotely in an unauthorised way.
- As cloning becomes more expensive, such approaches to obtaining fraudulent access to services will become more attractive.

Telco protection through the FMS

Prosecution

- Once a fraudster has been detected, and if it makes good business sense, the next step is to prosecute the fraudster.
- The principal piece of legislation used in the nation to prosecute cellular fraud shall be used.

Telco protection through the FMS

Presenting evidence in court

- Electronic data (e.g., call data) is admissible as evidence in criminal proceedings under the provisions of Criminal evidence and Justice Act.

Frauds in 4G

Malware Attacks

- Data-capable smartphones and tablets paired with large, wireless data pipes now attract significant attention from cybercriminal networks, today's “**organized crime.**” From a negligible baseline, **malware-based threats to mobile devices** were up in high rate according to McAfee® Labs™.
- Malicious software developers now readily take techniques developed for personal computers and adapt them to the limited footprint and technologies of mobile devices.

Frauds in 4G

- For example, ZITMO stands for “**Zeus in the Mobile,**” a reuse of the widely adopted Zeus toolkit that makes malware **programming easy for non-technical criminals.**
- ZITMO perpetrates **financial fraud by hijacking browsers and SMS authentication techniques.**

Frauds in 4G

Social Engineering

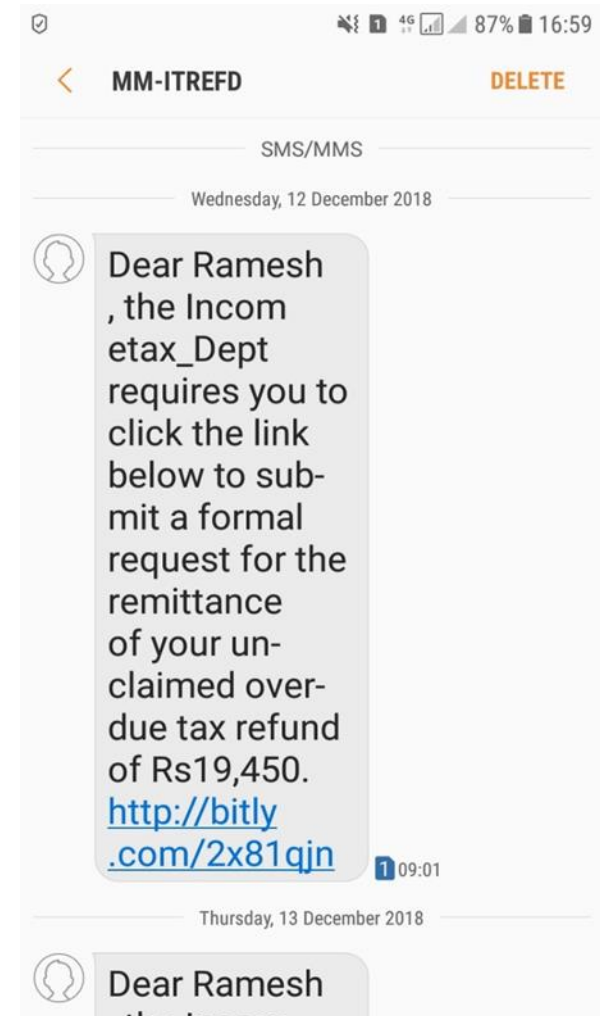
- Possibly more dangerous even than the spike in mobile malware is the spike in “**SMiShing**” and “phishing” attacks targeting the social relationships and curiosity of mobile users.



Frauds in 4G

Social Engineering

- These attacks involve malicious messages sent as emails or text messages to be consumed on the small screens and limited viewing areas of many mobile, smart devices.



Frauds in 4G

- The message dupes a user into clicking a link, installing an app, or going to a website.
- The result is frequently that identity and credentials are handed over by the user to the attackers willingly but unknowingly; and serious fraud is the outcome.

Frauds in 4G

Mobile to Mobile Attacks

- Unlike 3G traffic that tunnels directly into the core IP network from the mobile device, 4G traffic is all IP-based and can travel directly from mobile device to mobile device inside the wireless APN.
- This “peer to peer” (P2P) communication reduces backhaul traffic. However, it also permits mobile-to-mobile (Mob2Mob) attacks.

Frauds in 4G

- A compromised mobile device can target and scan large numbers of other, locally adjacent, mobile devices at once, consuming huge amounts of spectrum.
- This activity frequently goes unseen by the carrier because the wireless APN to which the device connects has limited instrumentation and few internal security capabilities.
- In addition to siphoning off spectrum, a mobile to mobile attack drains the battery on the victim's device by maintaining a network connection.

Frauds in 4G

- The attack can also cause a denial-of-service (DoS) situation due to signaling congestion.
- In an attack, the traffic may enter the network from one mobile device, perform an automated scan to look for devices with similar IP numbers (indicating that the devices are on the same subnet), and then reach back out over the 4G network to contact those devices.
- Once an attacker has exhausted one range of IP addresses, the attack moves to the next range and begins to attack and infect the new devices.

Frauds in 4G

- Unfortunately, the mere act of scanning for responding IP addresses of other mobile devices can cause severe DoS due to the previously mentioned signaling congestion.

Frauds in 4G

Machine to Machine Attacks

- The Internet of Things (IOT) includes not only devices managed by people, such as desktops and smartphones, but semiautomated and fully automated devices that control physical outcomes, such as traffic lights, pipeline pressure sensors, electrical grids, and water utilities.
- These devices are sometimes referred to as engaging in “machine-to-machine” (M2M) networking. Traditionally, these fixed-function devices were built without much concern for security, since they used limited, dedicated networks that were not connected to a public network.

Frauds in 4G

- Simple probing of the network (performed by vulnerability scanners as well as would-be attackers) can have adverse effects by destabilizing controllers.
- Hindering potential mitigations, field-based sensors are resource-constrained, with minimal memory and CPU to spare: there is no “room” to install firewalls or even basic security capabilities.
- In some cases, these devices run legacy, unpatched, and unpatchable operating systems.

Frauds in 4G

- In most cases, even modern M2M systems and devices are not intended to operate within the hostile and unhygienic environment of the Internet—yet that is what 4G will become without adequate security.
- When attacked, devices may just shut down—without warning, and sometimes without an easy or fast recovery. Disruption of ICS devices can lead to costly civil emergencies or loss of life.

Frauds in 4G

- This feared scenario is driving critical infrastructure operators and the governments that regulate them to invest heavily in understanding and implementing more rigorous security controls.
- For service providers looking to provide the networks for these burgeoning new M2M applications, a degree of security and awareness related to mobile-on-mobile attacks will be a business enabler.

Frauds in 4G

VOIP Attack

- VOIP attack tactics that have evolved on the Internet can be used just as effectively against VOLTE. VOLTE infrastructure must be accessible from any mobile device subscribing to voice services from the service provider.
- In this age of pre-paid accounts and phones purchased and topped-up from automated kiosks, restricting only “friendly” and recognized subscribers to the VOLTE infrastructure is difficult.

Frauds in 4G

- There are several thousand known attacks against VOIP protocols that range in outcome from capturing administrative privileges to denial-of-service attacks.
- The impact on voice services to consumer and business users, as well as emergency services that support police, fire, and medical resources, can be highly disruptive and dangerous and result in regulatory issues.
- Because VOLTE traffic remains largely within the wireless APN, carriers need different monitoring equipment to detect attacks as they move through the 4G infrastructure to the VOLTE service infrastructure.

Frauds in 4G

DNS Redirection Attack

- This is perhaps the most dangerous attack. A DNS Redirection attack intercepts and modifies the destination IP address of a DNS request coming from the victim.
- The purpose of this attack is to re-direct the original DNS request to a malicious DNS server. With a DNS server under adversarial control, victims can be re-routed to harmful web sites that install malware or phishing sites that steal login information.

How to deal with Frauds in 4G

- Fraudsters are always trying new techniques to bypass service providers controls and gain free access to services. This not only deprives the operator of revenue, but also damages their reputation with subscribers and partners.
- Fraud management teams must therefore be extremely agile to ensure they're able to quickly and efficiently respond to a changing fraud landscape.
- To cope with new types of fraud in VoLTE technology, it is vital that service provider implement faster techniques, such as machine learning.

How to deal with Frauds in 4G

- While there are limitations to machine learning, machines are much better than humans at dealing with, and processing, large datasets.
- They are able to detect and recognize thousands of features on a network event, instead of the few that can be captured by manually creating rules.

How to deal with Frauds in 4G

- These systems must be capable of finding patterns of behavior that are different from the normal VoLTE subscriber, and be able to identify suspicious activities and/or fraud attempts, no matter how they are perpetrated, regardless of the scheme used, or the origin/termination point of the fraud.
- To address these key capabilities, leading Fraud Management Systems (FMS) nowadays rely on algorithms.

How to deal with Frauds in 4G

- These can be designed and tuned to immediately identify the differences between fraudulent and legitimate events, to predict whether an event is likely be fraudulent before it is completed.
- As a result, a behavioral learning-based FMS is highly beneficial for service providers as it dramatically increases their knowledge of fraudsters' behavior, and quickly and efficiently generates potential fraud alerts.

Q & A



**E.R. Ramesh, M.C.A., M.Sc., M.B.A.,
98410 59353, 98403 50547
rameshvani@gmail.com**

Backup slides

- SS7 – Signaling System No.7
- HPLMN – Home Public Land Mobile Network
- SMST – Short Message Service Technical